Information Systems

MIS Chapter 5 Highlights

MIS Chapter 5 Highlights

Spyware is software that secretly gathers information about users while they browse the web.

Adware is a form of spyware that collects information about the user (without the user's consent) to determine which advertisements to display in the user's Web browser.

Phishing is sending fraudulent e-mails that seem to come from a legitimate source, such as a bank or university.

Keystroke loggers monitor and record keystrokes and can be software or hardware devices.

MIS Chapter 5 Highlights

Spoofing is an attempt to gain access to a network by posing as an authorized user in order to find sensitive information, such as passwords and credit card information.

Pharming is directing internet users to fraudulent Web sites with the intention of stealing their personal information, such as Social Security numbers, passwords, bank account numbers, and credit card numbers. Pharmers usually hijack an official Web site address, then alter its IP address so that users who enter the correct Web address are directed to the pharmer's fraudulent Web site.

MIS Chapter 5 Highlights

Computer fraud is the unauthorized use of computer data for personal gain.

Confidentiality means that a system must prevent disclosing information to anyone who is not authorized to access it.

Fault-tolerant systems ensure availability in the event of a system failure by using a combination of hardware and software.

Uninterruptible power supply (UPS) – This backup power unit continues to provide electrical power in the event of blackouts and other power interruptions.

Redundant array of independent disks (RAID) – a RAID system is a collection of disk drives used to store data in multiple places. If a drive in the RAID system fails, data stored on it can be reconstructed from data stored on the remaining drives.

Mirror disks – use two disks containing the same data and can be a suitable RAID system for a small organization.

A **virus** consists of self-propagating program code that is triggered by a specified time or event. When the program or operating system containing the virus is used, the virus attaches itself to other files, and the cycle continues.

Some indicators that a computer might be infected by a virus include:

- Some programs have suddenly increased in size.
- Files have been corrupted, or the user is unable to open some files.
- Hard disk free space is reduced drastically.
- The keyboard locks up, or the screen freezes.
- Available memory dips down more than usual.
- Disk access is slow.
- The computer takes longer than normal to start.
- There is unexpected disk activity, such as the disk drive light flashing even though the user is not trying to save or open a file.
- There are unfamiliar messages on the screen.

A **worm** travels from computer to computer in a network, but it does not usually erase data. Unlike viruses, worms are independent programs that can spread themselves without having to be attached to a host program.

A **logic bomb** is a type of Trojan program used to release a virus, worm, or other destructive code. Logic bombs are triggered at a certain time or by a specific event such as a user pressing the Enter key or running a certain program.

A **backdoor** is a programming routine built into a system by its designer or programmer. It enables the designer or programmer to bypass system security and sneak back into the system later to access programs or files.

A **denial-of-service (DOS)** attack floods a network or server with service requests to prevent legitimate users access to the system.

In the context of security, **social engineering** means using “people skills” such as being a good listener and assuming a friendly, unthreatening air to trick others into revealing private information. This attack takes advantage of the human element of security systems.

Biometric security measures use a physiological element that is unique to a person and cannot be stolen, lost, copied, or passed on to others.

Computer Emergency Response Team (CERT)

The CERT was developed by the Defense Advanced Research Projects Agency (part of the Department of Defense) in response to the 1988 Morris worm attack, which disabled 10 percent of the computers connected to the Internet. Many organizations now follow the CERT model to form teams that can handle network intrusions and attacks quickly and effectively.

Currently, CERT focuses on security breaches and denial-of-service (DoS) attacks and offers guidelines on handling and preventing these incidents. CERT also conducts a public awareness campaign and researches Internet security vulnerabilities and ways to improve security systems. Network administrators and e-commerce site managers should check the CERT Coordination Center for updates on protecting network and information resources.

A **firewall** is a combination of hardware and software that acts as a filter or barrier between a private network and external computers or networks, including the Internet.

An **intrusion detection system (IDS)** can protect against both external and internal access. It is usually placed in front of a firewall and can identify attack signatures, trace patterns, generate alarms for the network administrator, and cause routers to terminate connections with suspicious sources.

Some common **physical computer network security measures** include corner bolts, electronic trackers, and Identification (ID) badges.

A **virtual private network (VPN)** provides a secure “tunnel” through the Internet for transmitting messages and data via a private network. VPNs are an alternative to private leased lines or dedicated Integrated Services Digital Network (ISDN) lines and T1 lines.

Data encryption transforms data, called plaintext or cleartext, into a scrambled form called ciphertext that cannot be read by others.

A **comprehensive security system** must provide three levels of security:

Level 1: Front-end servers, those available to both internal and external users, must be protected against unauthorized access. Typically, these systems are e-mail and Web servers.

Level 2: Back-end systems (such as users' workstations and internal database servers) must be protected to ensure confidentiality, accuracy, and integrity of data.

Level 3: The corporate network must be protected against intrusion, denial-of-service attacks, and unauthorized access.